

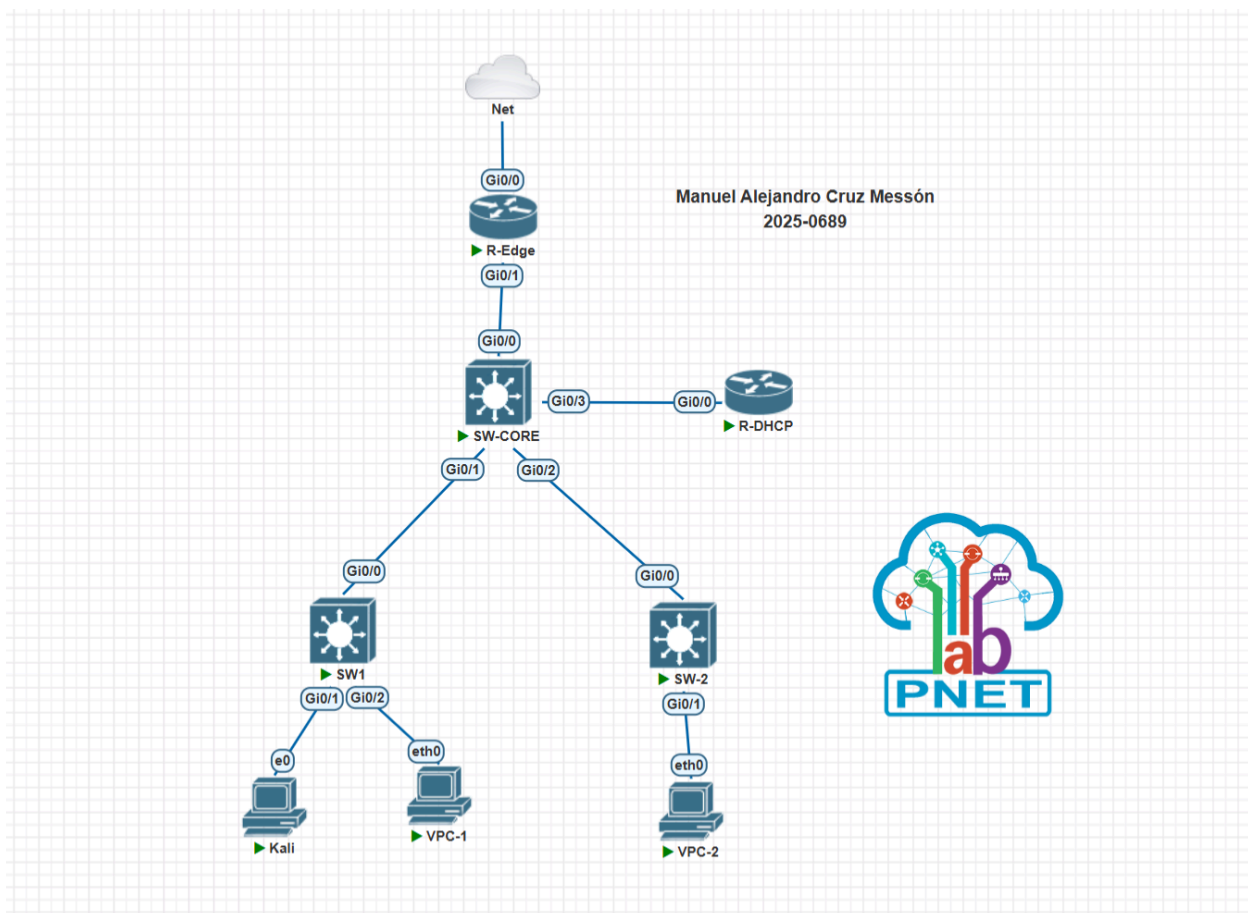
Ataque MAC Flooding

1. Objetivo del Laboratorio

El objetivo fundamental de este laboratorio es comprender y evaluar el comportamiento de un conmutador de Capa 2 (Switch) cuando su memoria dinámica de almacenamiento de direcciones físicas —la tabla CAM (Content Addressable Memory)— queda completamente saturada. El ejercicio práctico permite analizar el estado de falla conocido como **fail-open**. En este estado, el switch agota su capacidad de asignación de direcciones y degrada su funcionamiento operativo, pasando de comportarse como un dispositivo de conmutación inteligente a actuar como un concentrador (Hub). Esto expone los graves riesgos de confidencialidad en la red local al permitir que cualquier equipo intercepte el tráfico de los demás hosts.

1. Topología de la red

La topología representa una red de laboratorio estructurada bajo una arquitectura jerárquica simple, donde todos los dispositivos internos coexisten en la VLAN 89. La red cuenta con servicios automáticos de asignación de direccionamiento IP (DHCP) administrados por un enrutador dedicado, y salida a redes externas (Internet) a través de un enrutador de borde con traducción de direcciones



A. Hardware y Dispositivos

La infraestructura física y los nodos que componen la topología se distribuyen según sus roles funcionales en la red:

- **Dispositivos de Enrutamiento (Capa 3):**
 - **R-Edge:** Enrutador de borde perimetral encargado de la salida a redes externas.
 - **R-DHCP:** Enrutador dedicado exclusivamente a la administración y distribución de direccionamiento IP dinámico en la red local.
- **Dispositivos de Conmutación (Capa 2):**
 - **SW-CORE:** Switch central (Núcleo) que interconecta los enrutadores y distribuye el tráfico hacia los switches de acceso.
 - **SW-1 y SW-2:** Switches de acceso encargados de proveer conectividad directa a los nodos finales.
- **Dispositivos Finales (Hosts):**
 - **Kali:** Estación de trabajo orientada del atacante.
 - **VPC-1 y VPC-2:** Computadoras virtuales de escritorio (Virtual PCs) que actúan como usuarios finales de la red.
 - **Net:** Nube que simula el entorno de red externa o Internet.

B. Componentes de Software

Entorno lógico y sistemas operativos que corren sobre la infraestructura:

1. **Sistemas Operativos de Red:** Software basado en emulación de Cisco (IOS) para la gestión y ejecución de protocolos de red (CDP, DHCP, NAT, Routing) en los routers y switches.
2. **Sistemas Operativos de Hosts:**
 - **Kali Linux** instalado en la estación atacante.
 - OS ligero (**VPCS**) en las terminales de usuario para pruebas de conectividad básica (Ping, Traceroute).

C. Segmentación y Parámetros de Red

Definición del direccionamiento lógico, segmentación LAN y salida a Internet:

- **Segmento de Red Interno:** 192.168.89.0/24 (Máscara de subred 255.255.255.0).
- **VLAN Configurada:** VLAN 89, segmento único donde coexisten de forma nativa todos los dispositivos internos, switches (vía SVI) y routers.
- **Puerta de Enlace (Default Gateway):** 192.168.89.254 (Configurada en la interfaz Gi0/1 de R-Edge). Es el nodo encargado de recibir todo el tráfico interno con destino externo y realizar NAT/PAT para darle salida hacia Internet.

D. Interfaces Utilizadas

Dispositivo Origen	Interfaz Local	Dispositivo Destino	Interfaz Remota
R-Edge	Gi0/0	Net (Nube)	—
	Gi0/1	SW-CORE	Gi0/0
R-DHCP	Gi0/0	SW-CORE	Gi0/3
SW-CORE	Gi0/0	R-Edge	Gi0/1
	Gi0/3	R-DHCP	Gi0/0
	Gi0/1	SW1	Gi0/0
	Gi0/2	SW2	Gi0/0
SW-1	Gi0/0	SW-CORE	Gi0/1
	Gi0/1	Kali	e0
	Gi0/2	VPC-1	eth0
SW-2	Gi0/0	SW-CORE	Gi0/2
	Gi0/1	VPC-2	eth0
Kali	e0	SW1	Gi0/1
VPC-1	eth0	SW1	Gi0/2
VPC-2	eth0	SW2	Gi0/1

3. Objetivo del Script

El script mac-flooding.py es una herramienta de ataque ofensivo automatizado programada en Python (compatible con Scapy 2.5.0) diseñada para provocar el colapso de la tabla CAM de un switch mediante fuerza bruta. Sus metas técnicas específicas son:

- **Inundación de Direcciones de Origen (MAC Spoofing):** Generar tramas Ethernet legítimas en su estructura pero con direcciones MAC de origen falsas y únicas a una tasa de transferencia masiva (~10,000 paquetes por segundo).
- **Evasión de Filtros mediante Multi-protocolo:** Alternar aleatoriamente entre tres tipos de payloads (peticiones ARP falsas, paquetes UDP aleatorios y datos binarios crudos) para simular tráfico diverso y forzar al switch a registrar cada MAC falsa.
- **Interceptación Post-Saturación (Sniffing en Modo Hub):** Activar un sniffer promiscuo en el momento exacto en que la tabla CAM estimada se llena, con el fin de capturar el tráfico de otras víctimas que ahora el switch está inundando por todos sus puertos, buscando credenciales en texto plano en tiempo real.

4. Parámetros Usados

El script implementa el módulo argparse para capturar la interfaz física y define constantes internas estrictas para calibrar la agresividad del ataque:

- **-i, --interface (Obligatorio):** Especifica la tarjeta de red (ej. eth0, wlan0) sobre la cual se inyectarán las tramas clonadas.
- **PACKET_DELAY (0.0001s):** Margen de tiempo mínimo (0.1 milisegundos) entre paquetes dentro de una ráfaga para maximizar la velocidad de inyección.
- **BURST_SIZE (100):** Cantidad de paquetes agrupados por lote antes de ser enviados al socket de red en un solo ciclo de ejecución.
- **BURST_DELAY (0.01s):** Breve pausa entre ráfagas consecutivas para evitar el desbordamiento del búfer local del atacante.
- **CAM_TABLE_SIZE (8192):** Tamaño límite configurado para simular la capacidad de una tabla CAM estándar de un switch comercial (como la serie Cisco Catalyst típica de acceso).

5. Requisitos para Utilizar la Herramienta

Para que el entorno de laboratorio funcione y el script ejecute su lógica de bajo nivel, se deben cumplir los siguientes requisitos:

- **Privilegios de Root:** Al requerir la manipulación manual de cabeceras Ethernet de Capa 2 y el uso de sockets crudos (raw sockets), el script debe ejecutarse obligatoriamente con sudo.
- **Sistema Operativo Linux:** La suite de red de Scapy y los métodos para obtener

la dirección MAC real de la interfaz nativa dependen directamente del kernel de Linux.

- **Librería Scapy v2.5.0:** Framework esencial para construir la estructura de datos de las tramas de red de forma personalizada.
- **Conexión Física/Directa al Switch:** El atacante debe estar conectado a un puerto de acceso del switch bajo evaluación. Si se ejecuta a través de un router o una red segmentada por Capa 3, las MACs falsas se perderán en el camino y el ataque no afectará al switch objetivo.

6. Documentación del Funcionamiento del Script

La arquitectura del script se basa en la concurrencia asíncrona mediante hilos de ejecución (threading), dividiendo el ataque en tres procesos simultáneos:

Fase 1: Inicialización y Monitoreo Pasivo

- Al arrancar, el script lanza un hilo secundario con la función `start_sniffer()`, la cual corre de fondo de forma pasiva analizando las tramas de la interfaz. Sin embargo, mantiene una bandera interna `sniff_active = False` para no procesar datos hasta que la red colapse.
- Simultáneamente, se inicia el hilo `stats_monitor()`, encargado de renderizar en pantalla una interfaz visual cada 5 segundos. Esta consola muestra el tiempo activo, los paquetes enviados, el rendimiento (pkt/s) y una barra de progreso que estima el porcentaje de llenado de la tabla CAM del switch objetivo.

Fase 2: Inundación Agresiva (Modo 1, 2 y 3)

El hilo principal entra en el bucle infinito `flood_loop()`, enviando ráfagas continuas de 100 paquetes utilizando la función de Capa 2 `sendp()`. Por cada paquete de la ráfaga, la función `build_flood_frame()` genera una dirección MAC única con el prefijo de administración local (02:XX:XX...) y selecciona al azar una de estas tres estructuras:

3. **Modo 0 (ARP Request):** Genera una petición ARP dirigida a la dirección de broadcast (ff:ff:ff:ff:ff:ff) mapeando IPs de origen y destino totalmente aleatorias.
4. **Modo 1 (UDP sobre IP):** Crea un paquete de transporte UDP con puertos e IPs aleatorias y le añade una carga útil binaria basura mediante `os.urandom()`.
5. **Modo 2 (Trama Cruda):** Ensambla una trama Ethernet pura sin cabeceras de Capa 3, inyectando directamente datos binarios aleatorios sobre la capa de enlace.

Fase 3: Activación del Modo Hub y Captura de Datos

- Cuando el contador de MACs únicas guardadas en el set global alcanza la métrica de CAM_TABLE_SIZE (8,192 entradas), el script calcula que el switch real ha agotado su memoria física y que ha empezado a descartar las MACs legítimas más antiguas para dar espacio a las nuevas, entrando en modo fail-open.
- El script cambia la bandera sniff_active = True. A partir de este momento, el sniffer de segundo plano empieza a capturar los paquetes de otros equipos de la red que el switch ahora se ve obligado a retransmitir por todos sus puertos (comportamiento de Hub).
- La función packet_sniffer() decodifica las cargas TCP útiles y filtra las cadenas de texto plano buscando patrones sensibles: PASSWORD, PASS, USER, LOGIN o AUTH. Si hay coincidencia, las imprime con una alerta en consola.

Fase 4: Cierre Seguro y Volcado Forense

- Al presionar Ctrl+C, el manejador cleanup() interrumpe los hilos.
- Si el sniffer logró capturar tramas interceptadas de otras máquinas de la red durante la Fase 3, el script utiliza la función wrpcap() para empaquetar y guardar automáticamente toda la sesión en el archivo local /tmp/mac_flood_capture.pcap para su posterior análisis en herramientas como Wireshark.

7. Documentación de Contra-medidas

Para mitigar por completo este tipo de ataques de denegación de servicio y espionaje en la infraestructura de conmutación, se deben implementar las siguientes defensas a nivel de Capa 2:

- **Port Security (Limitación de MACs):** Es la contramedida estándar más efectiva. Consiste en configurar las interfaces de acceso del switch para limitar estrictamente el número de direcciones MAC que pueden aprender dinámicamente (por ejemplo, un máximo de 2 MACs por puerto de usuario).
 - Acción de Violación: Se debe configurar el puerto en modo shutdown o restrict. En cuanto el script envíe la tercera dirección MAC falsa, el switch bloqueará el puerto del atacante de inmediato, notificando al administrador vía SNMP.
- **Sticky MAC (MACs Persistentes):** Complemento de Port Security que permite al switch aprender dinámicamente las direcciones MAC legítimas de los equipos conectados y guardarlas directamente en la configuración en ejecución (running-config). Esto evita que tramas falsas inyectadas a alta velocidad desplacen los registros legítimos de la tabla de memoria.

- **Control de Acceso basado en el Estándar IEEE 802.1X:** Implementar una infraestructura de autenticación donde cada puerto del switch requiera una validación de identidad (mediante certificados o credenciales de usuario centralizadas en un servidor RADIUS/TACACS+) antes de levantar el enlace de datos. Si el dispositivo que corre el script no está autenticado, el switch mantiene el puerto aislado en una VLAN de cuarentena o sin comunicación, impidiendo cualquier intento de inundación.